

Mapa de respuestas al cuestionario de seguridad de Amazon (SP-API)

Guía para responder el "Perfil de proveedor de soluciones" de forma veraz. Cada fila indica la respuesta y la evidencia que la respalda. Solo marca "Sí" cuando la acción del checklist esté hecha (ver más abajo).

Pregunta del formulario	Respuesta	En qué se apoya
¿Controles de red: firewalls, IDS/IPS, antivirus/antimalware y Sí segmentación de red?		La infraestructura es serverless: Cloudflare aporta WAF, protección DDoS y filtrado de red en el borde; Supabase (PostgreSQL gestionado en la UE) aporta aislamiento de red y parcheo gestionado. Los equipos de trabajo usan antivirus/antimalware del sistema operativo.
¿Restringís el acceso a la información de Amazon según la Sí función del usuario?		Política de Contraseñas y Accesos, §4 (mínimo privilegio; solo el responsable accede a producción; RLS por vendedor).
¿Ciframos la información de Sí Amazon en tránsito?		TLS 1.2+ en todo el tráfico. Política, §6.
¿Plan de respuesta a incidentes con roles definidos, revisiones Sí cada 6 meses y notificación en 24 h?		Documento "Plan de Respuesta a Incidentes" (roles §2, revisión 6 meses §7, notificación 24 h §6).
¿El plan incluye notificar a security@amazon.com en 24 h Sí desde la detección?		Plan de Respuesta a Incidentes, §6.
¿Requisitos de contraseña: mín. Sí 12 caracteres con especiales, MFA, caducidad 365 días y rotación anual?		Política de Contraseñas y Accesos, §2 y §3.
¿Las credenciales se almacenan de forma segura (no en repos Sí públicos, no compartidas, no hardcodeadas)?		Política, §5 (secretos solo en Cloudflare; tokens de vendedor cifrados AES-GCM; nunca en el código ni en repos públicos).
Terceros con los que compartís Sí información de Amazon	Solo subencargados de infraestructura: Cloudflare (cómputo serverless) y Supabase (PostgreSQL gestionado en la UE). No se cede a ningún otro tercero.	
Fuentes externas (no Amazon) de Sí información de Amazon	Ninguna. Toda la información se obtiene de las API oficiales (SP-API y Amazon Ads API) con credenciales autorizadas.	

Checklist para que las respuestas "Sí" sean CIERTAS (hazlo antes de enviar)

- [] Activar MFA en: Amazon (Seller Central + Solution Provider Portal), Cloudflare, Supabase, GitHub y el correo fernando.gil@me.com.

- [] Poner contraseñas de 12+ caracteres con especiales, únicas por servicio, en un gestor de contraseñas.
- [] Confirmar que ningún secreto está en el repositorio ni escrito en el código (los secretos viven solo en Cloudflare). En SellerBrain ya es así.
- [] Confirmar que los refresh tokens de vendedor se guardan cifrados (AES-GCM). Ya implementado en el Worker.
- [] Aprobar y fechar los dos documentos (Plan de Incidentes y Política de Contraseñas).
- [] Poner un recordatorio cada 6 meses para revisar el Plan de Incidentes, y anual para la Política de Contraseñas.
- [] Marcar como antivirus/antimalware activo en los equipos de trabajo.

Notas

- Roles restringidos / PII: no se solicitan. SellerBrain no procesa datos personales de compradores, lo que evita el nivel de revisión más estricto.
- Guarda estos tres documentos (PDF o enlace) por si Amazon los pide en el caso que abrirá tras el registro.